PERFECTION IN AUTOMATION
A MEMBER OF THE ABB GROUP

mapp SERVICES

Declaration of conformity Electronic records / Electronic signatures

Version: MpAudit, MpUser and MpUserX in mapp Services V5.0.0 or later

We reserve the right to change the content of this document without prior notice. B&R is not liable for technical or printing errors and defects in this document. In addition, B&R assumes no liability for damages that are directly or indirectly attributable to the delivery, performance and use of this material. We point out that the software and hardware names and brand names of the respective companies used in this document are subject to general trademark, brand or patent protection.

I Table of contents

1 The US Food and Drug Administration (FDA) 3

2 Regulation 21 CFR Part 11 ("Part 11" for short) 3

3 Application of FDA regulations 3

4 "Regulated" electronic records 3

5 Existing interpretation methods and recommendations 3

6 Evaluation of mapp Services 4

7 General considerations / requirements of Part 11 4
7.1 Validation 4
7.2 Access protection 4
7.3 Audit trails 4
7.4 Record retention, protection, reproducibility and retrievability 5
7.5 Document information 5
7.6 Electronic signature 5
7.7 Certificate to FDA 5

8 Meeting the requirements with mapp Services 6
8.1 Access protection with mapp User (MpUser, MpUserX) 6
8.2 Audit trails in MpAudit 7

9 Evaluation list for mapp Services 8
9.1 Additional procedures and controls for open systems 9
9.2 Signed electronic records 9
9.3 Electronic signatures (general) 10
9.4 Electronic signatures (non-biometric) 10
9.5 Electronic signatures (biometric) 11
9.6 Controls for identification codes (ID) and passwords 11

Copyright © B&R - Subject to modification

1 The US Food and Drug Administration (FDA)

This technical white paper discusses the functionality of mapp Audit (mpAudit) and mapp User (MpUser, MpUserX) in mapp Services V5.0.0 or later with respect to the extent to which they conform with Section 11 of the US Food and Drug Administration (FDA) Regulation 21 CFR Part 11 regarding electronic records and electronic signatures.

US Food and Drug Administration (FDA) Regulation 21 CFR Part 11 ("Part 11" for short) regarding electronic records and signatures has been in effect since August 20th, 1997.

2 Regulation 21 CFR Part 11 ("Part 11" for short)

Part 11 defines the FDA's acceptance criteria for using electronic records and electronic signatures in place of paper documents. It requires that electronic records and signatures must be as trustworthy, reliable and equivalent as conventional records.

3 Application of FDA regulations

FDA regulations are also often applied in the biosciences (also referred to as life sciences) such as food processing, cosmetics and personal care products.

4 "Regulated" electronic records

The application of regulations such as Part 11 (or its respective implementation in national legislation) is mandatory when using electronic records and electronic signatures. However, the regulations are only applicable within the respective national context and even there only for "regulated" electronic records. Beyond the use of electronic records and signatures, however, it is still possible to use conventional paper documents and handwritten signatures, or a combination of the two.

5 Existing interpretation methods and recommendations

There are a number of interpretation methods and recommendations available on this topic from a variety of industrial associations and regulatory authorities. Those listed here below can be considered the most important/relevant.

ISPE - The "International Society for Pharmaceutical Engineering" (ISPE) is an international society of engineers and companies active in productive, regulated industrial branches and count over 22,000 members today.

PDA - The Parenteral Drug Association (PDA) as International Association for Pharmaceutical Science and Technology is an international non-profit organization of over 11,000 scientists active in research and development, production, quality control and regulation of pharmaceuticals and related products. The organization also offers numerous training programs for public administration and the university sector.

Copyright © B&R - Subject to modification

6 Evaluation of mapp Services

mapp Services functions (MpAudit, MpUser, MpUserX) have been evaluated with respect to the requirements of Part 11 (FDA).

In summary it can be said that the functional requirements of electronic records and electronic signatures are satisfied. Conditions that warrant special consideration are noted explicitly. Technical details can be found in the respective product documentation.

However, we would likely to explicitly point out that for many applications, operation in conformity with the relevant guidelines is only guaranteed provided that the regulated company implements the necessary organizational measures and standard operating procedures (SOPs).

7 General considerations / requirements of Part 11

The benefits of electronic archiving are lower costs and higher efficiency. This is achieved through simplified storage and handling in comparison to paper documents. Access and referencing to trend data and alarms yields better process control and improved access to information and process data.

21 CFR Part 11 takes into account that the risk of manipulation, misinterpretation and changes without trace is considerably higher with electronic records and electronic signatures than with conventional paper records and handwritten signatures, or are more difficult to detect. Additional measures are required for exactly this reason.

The terms "electronic record” / "electronic document" mean any combination of text, graphics, data, audio, pictorial or other information representation in digital form, that is created, modified, maintained, archived, retrieved or distributed by a computer system.

The term "electronic signature" means a computer data compilation of any symbol or series of symbols executed, adopted, or authorized by an individual to be the legally binding equivalent of the individual’s handwritten signature.

The potential risks yielded the following general requirements from Part 11:

7.1 Validation

The FDA defines validation as the documented act of demonstrating that a procedure, process, and activity will consistently lead to the expected results.

7.2 Access protection

Systems must limit access to only authorized, qualified personnel. In open systems, additional security measures must be implemented to ensure this.

7.3 Audit trails

All regulated operator actions which create, modify or delete electronic records must be recorded in a secure, time-stamped, computer-generated audit trail.

Copyright © B&R - Subject to modification

7.4 Record retention, protection, reproducibility and retrievability

Systems must have the capability to retain, protect and readily retrieve records. Systems must be able to reproduce electronic records in both human readable and electronic form.

7.5 Document information

Respective controls must exist in regard to access, revision, distribution and use of documentation for operation and maintenance.

7.6 Electronic signature

Systems must provide measures to ensure that utilization is limited to the genuine owner only and that attempted use by others is promptly detected and recorded. Written policies must be in place that hold individuals responsible for actions initiated under their electronic signature.

Electronic signatures must not be reused or reassigned in any way. The intended purpose of an electronic signature must also be clearly indicated.

Non-biometric systems must provide two distinct identification components (e.g. user login and password) to be entered when signing. At least the password must be re-entered for any subsequent signing action within the same session.

7.7 Certificate to FDA

Written certification must be provided to the FDA Office of Regional Operations that all electronic signatures in use are the legally binding equivalent of traditional handwritten signatures.

Copyright © B&R - Subject to modification

8 Meeting the requirements with mapp Services

8.1 Access protection with mapp User (MpUser, MpUserX)

- MpUser and MpUserX make it possible to represent user data with a username and password. The password is saved in encrypted and checksum-verified format when installing the appropriately configured application software on Automation Runtime (typically on a PLC), and is therefore secured against external access. If necessary, exporting the configuration files must be explicitly prevented by the application.
- User groups and their rights can be set in Automation Studio and modified during runtime.
- Use of MpUser or MpUserX functionality in accordance with Part 11 must occur explicitly in the application software.
- Additional security measures are required if it is to be used in open systems.
- MpUser and MpUserX support password expiration. A new password must be set after a defined time has passed. It is also possible to check password quality and minimum password length.
- Users can be blocked automatically after a definable number of failed login attempts. Their account can only be reopened by an administrator.
- A new password can be set after the initial login. An auto-logout function is possible (after definable time has passed without user interaction).
- In combination with MpAudit, events related to access security are logged by the system (e.g. login, logout, input of incorrect user ID or password, user blocked after multiple attempts to enter an incorrect password, password change by user).

Copyright © B&R - Subject to modification

8.2 Audit trails in MpAudit

Audit trails are not necessary for electronic records generated automatically by the system, which the operator is not able to modify or delete.

Audit trails are absolutely mandatory if production-relevant data is modified, changed or deleted by operator actions performed by the user during normal operation.

mapp Audit (MpAudit) records the events to be logged in the application software on the runtime system (typically the PLC) in the audit trail. The audit trail configuration can be exported from the runtime system. If this is not desired, this function must be explicitly prevented by not implementing it in the application software.

The following considerations (on the runtime system) apply to plant operation

- Process data (e.g. process values, process or operating messages, etc.) are stored without any option for the operator to change this data. The functions must be implemented in the application software. The data must be stored on the runtime system in tamper-resistant files/containers.

- Recorded HMI operations and events are stored in tamper-resistant files/containers. All events (old value, new value, user ID, date and timestamp, operation) are recorded in the audit trail report (operation log).

- MpAudit functions also offer the ability to log any additional events and data in the audit trail (e.g. application specific loading of a configuration file).

- The audit report can be exported in an encrypted *.zip file, decrypted on a PC and printed. The exported audit archive must be kept available through additional measures for the duration of the retention period.

Copyright © B&R - Subject to modification

9 Evaluation list for mapp Services

The following checklist for a system assessment originates from an ISPE / PDA document. The system assessment checklist covers all requirements, not only those which can be satisfied by technological solutions. To meet certain requirements of 21 CFR Part 11, the regulated company must implement corresponding procedural controls. The rules and standards always relate to the customer-specific application that was implemented with mapp Services. This means that application-specific implementations in source code and/or configuration must be used properly. The following solutions specified cannot be viewed on their own, but rather are only valid in conjunction with specific procedures and organizational measures. If system access is controlled by persons who are responsible for the content of the electronic records, then the system is defined as "closed." This section discusses the respective evaluation that is necessary.

Paragraph / detail	Questions / requirements	Comments
11.10(a) Item 1	Is the system validated?	Validation of the application or system is solely the responsibility of the regulated company. The only responsibility of the supplier is to provide systems capable of validation. B&R's internal quality management system, which can be audited at any time, is based on ISO 9001:2008.
11.10(a) Item 2	Is it possible to discern invalid or altered records?	**HMI / Operator station** All relevant operator input is documented in the audit trail along with, e.g. date, timestamp, action and old/new value. The responsible MpAudit functions must be used when creating the application software. In addition to user input during operation, the application software developer also generates definable results and data that can be documented in the audit trail. Unauthorized changes are prevented when MpUser or MpUserX is used correctly (in accordance with its documentation). **Automation Studio (engineering tool);** Changes made during project development in Automation Studio are not traceable.
11.10(b) Item 1	Is the system capable of producing accurate and complete copies of electronic records on paper?	Printed copies can be made of all recorded process data (e.g. process values, alarms and messages) using third-party tools (e.g. Windows editor).
11.10(b) Item 2	Is the system capable of producing accurate and complete copies of records in electronic form for inspection, review and copying by the FDA?	All recorded process data (e.g. process values, alarms and messages) can be provided in the form of text files.
11.10(c)	Are the records readily retrievable throughout their retention period?	Storage and archiving are solely the responsibility of the regulated company. Records can be archived in a readable format (e.g. on DVD). B&R assumes that these devices and formats will also be readable in the future. The regulated company should specify retention periods and define procedures for archiving, backup and retrieval of electronic records.
11.10(d)	Is system access limited to authorized individuals?	This requirement refers to physical access as well as logical access to the system. MpUser or MpUserX only allows login via the HMI on the machine when the correct login data (username and password) are used. The application must ensure that MpUser or MpUserX is used correctly. The regulated company must ensure that only persons who have a legitimate business-related reason to use the system are able to physically access the system. Access using an engineering tool (Automation Studio) is to be secured with appropriate additional measures.
11.10(e) Item 1	Is there a secure, computer generated, timestamped audit trail that records the date and time of operator entries and actions that create, modify, or delete electronic records?	MpAudit can be used to generate a tamper-resistant audit trail. The application software must ensure proper use of MpAudit in order for the records to be complete. The audit trail itself is managed in the system in a checksum-verified and tamper-resistant manner.
11.10(e) Item 2	Is the previously recorded information still available after electronic data has been changed? (or is it, for example, superimposed by the change?)	Electronically recorded information cannot be changed by the user. Loss of data by overwriting the audit trail ring buffer must be prevented using appropriate measures in the application software.
11.10(e) Item 3	Is an electronic record's audit trail retrievable throughout the duration of the record's retention period?	Storage and retrieval of electronic recordings are solely the responsibility of the regulated company. MpAudit provides the necessary export formats (e.g. text).
11.10(e) Item 4	Is the audit trail available for review and copying by the FDA?	MpAudit supports text exports. This allows the regulated company to provide the required information.

Paragraph / detail	Questions / requirements	Comments
11.10(f)	If the sequence of system steps or events is important, is this enforced by the system	MpAudit supports inclusion of these steps and events provided that it is integrated appropriately into the application software.

Copyright © B&R - Subject to modification

	(e.g., as would be the case in a process control system)?	
11.10(g)	Does the system ensure that only authorized individuals can use the system, electronically sign records, access the operation or computer system input or output device, alter a record, or perform other operations?	Only authorized persons can access the system via user ID (user login) and password. In the area of HMI / operator stations, this is ensured by appropriate use of MpUser or MpUserX. The regulated company should define how access is restricted to authorized individuals (e.g. assignment of automation objects and system applications), including special rights for administrators.
11.10(h)	If it is a requirement of the system that input data or commands can only come from certain input devices (e.g. terminals), does the system check the validity of the source of any data or instructions received? (Note: This applies where data or instructions can come from more than one device, and therefore the system must verify the integrity of its source, such as a network of weigh scales, or remote, radio controlled terminals.)	Provided that it is implemented appropriately in the application software, MpUser or MpUserX supports the assignment of different rights on different terminals. This also requires additional measures to be implemented in the application software.
11.10(i)	Is there documented training, including on-the-job training for system users, developers, IT support staff?	B&R offers both standardized training courses and courses tailored to customer projects, which must be planned with the customer and performed separately. Planning and completion of the training courses is the responsibility of the regulated company. Information about available seminars can be found on the B&R website.
11.10(j)	Is there a written policy that makes individuals fully accountable and responsible for actions initiated under their electronic signatures?	Implementation of procedural guidelines is solely the responsibility of the regulated company.
11.10(k) Item 1	Is the sharing, access to and use of the operational and service documentation for the system controlled?	Implementation of procedural guidelines is solely the responsibility of the regulated company.
11.10(k) Item 2	Is there a formal change control procedure for system documentation that maintains a time sequenced audit trail for those changes made by the pharmaceutical organization?	Implementation of procedural guidelines is solely the responsibility of the regulated company.

mapp Audit (MpAudit) and mapp User (MpUser, MpUserX) are to be used exclusively on closed systems.

9.1 Additional procedures and controls for open systems

If system access is not controlled by persons who are responsible for the content of the electronic records, then the system is defined as "open." This section discusses the respective evaluation that is necessary. mapp Audit (MpAudit) / mapp User (MpUser, MpUserX) are designed for use in closed systems. Additional measures are required if they are to be used in open systems.

Paragraph / detail	Questions / requirements	Comments
11.30 Item 1	Is data encrypted?	MpAudit / MpUser / MpUserX are intended for use in closed systems. Additional security measures should be taken using commonly available standard tools for encryption.
11.30 Item 2	Are digital signatures used?	MpAudit / MpUser / MpUserX do not currently include digital signature functionality. Appropriate additional measures must be implemented.

9.2 Signed electronic records

Paragraph / detail	Questions / requirements	Comments
11.50 Item 1	Do signed electronic data sets contain the following information? Printed name of signee Date and time of signing Meaning of the signature (such as approval, review, responsibility)	Signatures for the respective purposes are to be established in the application software.

Copyright © B&R - Subject to modification

11.50 Item 2	Is the above information shown on displayed and printed copies of the electronic record?	The described content must be created in the application software.
11.70	Are signatures linked to their respective electronic records to ensure that they cannot be cut, copied, or otherwise transferred by ordinary means for the purpose of falsification?	Electronic records are checksum-verified and can be encrypted upon export. A configuration must be set appropriately in the application software. Display of the electronic signature in the audit trail can be implemented in the application software.

9.3 Electronic signatures (general)

Paragraph / detail	Questions / requirements	Comments
11.100(a) Item 1	Are electronic signatures unique to an individual?	User data on a machine is unique (username + password). This makes it possible for the application software to ensure that an electronic signature is uniquely assigned to an individual. In addition, the regulated company must ensure the uniqueness of the electronic signature to an individual.
11.100(a) Item 2	Are electronic signatures ever reused by or reassigned to anyone else?	The regulated company has to ensure and is responsible that a user ID (user login) is assigned to one individual only.
11.100(b)	Is the identity of an individual verified before an electronic signature is allocated?	Implementation of procedural guidelines is solely the responsibility of the regulated company.

9.4 Electronic signatures (non-biometric)

Paragraph / detail	Questions / requirements	Comments
11,200 (a)(1)(i)	Is the signature made up of at least two components, such as a user ID and password, or an ID card and password?	MpUser and MpUserX support user identification with a user ID and a password.
11,200 (a)(1)(ii)	If multiple signatures are applied in the course of a continuous session, is the password required for every signature? (Note: both components must be entered for the first signature in a session)	This requirement must be implemented in the application software.
11,200 (a)(1)(iii)	If signatures are not performed in a continuous session, are both components of the electronic signature required for each signature?	This requirement must be implemented in the application software.
11,200 (a)(2)	Are non-biometric electronic signatures only used by their genuine owners?	Organizational measures are solely the responsibility of the regulated company. Implementation of procedural guidelines is solely the responsibility of the regulated company.

Copyright © B&R - Subject to modification

11,200 (a)(3)	Would an attempt to falsify an electronic signature require the collaboration of at least two individuals?	Initial user data is defined by the administrator. The administrator is unable to misuse this data, however, since the user is obligated to choose a new password the first time they login (assuming this is implemented in the application software). The regulated company must implement additional procedural guidelines to prevent disclosure of passwords.

9.5 Electronic signatures (biometric)

Paragraph / detail	Questions / requirements	Comments
11.200(b)	Has it been shown that biometric electronic signatures can be used only by their genuine owner?	Third-party hardware and software components must be used, because MpUser and MpUserX do not have an integrated solution. The integrity of such solutions must be evaluated separately.

9.6 Controls for identification codes (ID) and passwords

If tokens, cards, and other devices bearing or generating identification code or password information are used for the electronic signatures, then the system must be evaluated according to the requirements in this section.

Paragraph / detail	Questions / requirements	Comments
11.300(a)	Are controls in place to maintain the uniqueness of each combined identification code and password, such that no individual can have the same combination of identification code and password?	This must be done by creating and implementing an appropriate configuration in the application software. Implementation of procedural guidelines is solely the responsibility of the regulated company.
11.300(b) Item 1	Are procedures in place to ensure that the validity of identification codes is periodically checked?	Implementation of procedural guidelines is solely the responsibility of the regulated company.
11.300(b) Item 2	Do passwords periodically expire and need to be revised?	A password expires after a specified number of days. With MpUser and MpUserX, you can prevent the same password from being directly reused. Appropriate care must be taken in the application software. Implementation of procedural guidelines is solely the responsibility of the regulated company.
11.300(b) Item 3	Is there a procedure for recalling identification codes and passwords if a person leaves or is transferred?	With MpUser and MpUserX, user accounts can be deactivated. Implementation of procedural guidelines is solely the responsibility of the regulated company.
11.300(c)	Is there a procedure for changing an identification code or password if it is potentially compromised or lost?	Users can change their password at any time if they feel it has been compromised provided that appropriate functions are used in the application software. It is also possible to deactivate the user. The password can be reset by the administrator at any time if it is lost or forgotten. Implementation of procedural guidelines is solely the responsibility of the regulated company.
11.300(d) Item 1	Is there a procedure for detecting attempts at unauthorized use and for informing security?	Failed access attempts ("Login denied") are logged in the audit trail and can be identified and traced there. If a user is blocked (too many failed login attempts) an alarm is triggered. Appropriate configurations must be entered in the application software. Implementation of procedural guidelines is solely the responsibility of the regulated company.

Copyright © B&R - Subject to modification

11.300(d) Item 2	Is there a procedure for reporting repeated or serious attempts at unauthorized use to management?	Implementation of procedural guidelines is solely the responsibility of the regulated company.

Copyright © B&R - Subject to modification